OWASP Compliance Evidence Checklist

Final deliverable 8 — SENG 34213 System Development Project

Hotel Website (HW), Forever Hotel. Snapshot: 2026-10-25 (Asia/Colombo).

Assessment status: NOT fully compliant — known dependency blockers and unverified operational controls

Source revision: `63673ba704b4ae645a8f067e246309b6fb0f03d0`. Branch: `docs/190-release-setup-and-demo-evidence`.

The reports were prepared after this commit; they do not certify a deployed release.

Scope is the HW repository plus identified API Gateway evidence, not the complete multi-subsystem hotel system.

Guideline source: SENG34213_System_Development_Project (1).pdf, section 10.1, printed page 40. The guideline suggests nested testing/security paths; these files are directly under `documents/` as requested by the user.

1. Assessment method and standard

Uses the A01–A10 categories and required controls in guideline section 8.1 (printed pages 35–36), matching its OWASP 2021-style category names. This is a repository evidence assessment, not an independent audit, certification or assertion that every control passed. Review combines source, current automated results and npm advisory scans. No real secrets, card data or provider calls were required.

2. Checklist

A01 — Broken Access Control

Field	Assessment
Status	Partial — implemented guest ownership; live integration rerun blocked
Implemented evidence	JWT guards and guest-scoped repositories; invalid JWT and frontend return tests; foreign reads intentionally return 404, not the guideline example 403.
Evidence location	backend/src/common/guards/jwt-auth.guard.ts; test/integration/http-consumer-contracts.integration-spec.ts
Gap / required action	Rerun cross-guest DB scenarios and record the 401/404 anti-enumeration contract deviation for review. Public catalogue/enquiry/verified webhook routes are intentionally public.
Owner	HW development plus security/infra owners; final reviewer pending

A02 — Cryptographic Failures

Field	Assessment
Status	Partial
Implemented evidence	bcrypt cost 12; timing-safe HMAC/JWT verification; 24h JWT; HttpOnly, production Secure cookie. Unit tests pass.
Evidence location	backend/src/guests/password-hasher.service.ts; common/utils/jwt-token.service.ts; frontend/src/features/auth/actions.ts
Gap / required action	Staging TLS/certificate proof pending. Refresh-token hashing is not applicable to an unimplemented refresh-token store; bearer JWTs are not claimed to be hashed in browser cookies.
Owner	HW development plus security/infra owners; final reviewer pending

A03 — Injection

Field	Assessment
Status	Partial
Implemented evidence	Parameterized SQL/ORM, strict DTO whitelist, bounded inputs and React escaping. Unit validation/URL tests pass.
Evidence location	backend/src/database/repositories/booking.repository.ts; common/pipes; frontend/tests/rooms.test.mjs
Gap / required action	Current SQL-injection/card-field HTTP canaries blocked by DB setup; no exhaustive penetration/XSS assessment is claimed.
Owner	HW development plus security/infra owners; final reviewer pending

A04 — Insecure Design

Field	Assessment
Status	Partial
Implemented evidence	Signed previews bind guest/state/revision; sorted locks, idempotency and provider reconciliation; ADR 001–003 document decisions.
Evidence location	documents/architecture/; backend/src/bookings/booking-management.service.ts
Gap / required action	Original SDS security threat model and formal design-review approval are not bundled/verified. Resolve policy/provider/deposit/refund design gaps.
Owner	HW development plus security/infra owners; final reviewer pending

A05 — Security Misconfiguration

Field	Assessment
Status	Partial

Field	Assessment
Implemented evidence	Production disables Swagger and rejects SQL logging/schema synchronization; generic error responses/event-only failure logs; secret examples are placeholders.
Evidence location	backend/src/config/env.validation.ts; common/filters/all-exceptions.filter.ts
Gap / required action	Host, gateway TLS, secret rotation and container hardening need deployment evidence. Replace every local demo/default credential before release.
Owner	HW development plus security/infra owners; final reviewer pending

A06 — Vulnerable and Outdated Components

Field	Assessment
Status	FAIL — release blocker
Implemented evidence	Fresh npm advisory scans found a critical frontend issue and three high backend affected-package findings.
Evidence location	frontend/package-lock.json; backend/package-lock.json; audit snapshot below
Gap / required action	Upgrade/retest affected dependencies, rescan all scopes, and demonstrate no high/critical findings in the release CI. No dependency fix was applied while preparing reports.
Owner	HW development plus security/infra owners; final reviewer pending

A07 — Identification and Authentication Failures

Field	Assessment
Status	Partial / required control gap
Implemented evidence	bcrypt/JWT validation, secure cookie properties and gateway per-process login rate limit have tests.
Evidence location	backend/src/guests/; api-gateway/src/app.ts; frontend/src/features/auth/actions.ts
Gap / required action	Account-based lockout after N failures is not demonstrated. Logout does not revoke copied JWTs. Distributed throttling/session decisions, recovery/social auth remain pending.
Owner	HW development plus security/infra owners; final reviewer pending

A08 — Software and Data Integrity Failures

Field	Assessment
Status	Partial
Implemented evidence	Committed lockfiles, npm ci and reviewed digest-pinned staging tooling; webhook authenticity and reconciliation unit tests pass.

Field	Assessment
Evidence location	package lockfiles; .github/workflows/staging-release.yml; backend/src/payments/payhere-provider.ts
Gap / required action	Actual pipeline/review/provenance artifacts and live rollback are not verified by mocked tests.
Owner	HW development plus security/infra owners; final reviewer pending

A09 — Security Logging and Monitoring Failures

Field	Assessment
Status	Partial
Implemented evidence	Secret canary logging regression passes; provider failures emit controlled events; no raw billing/provider responses in intended log paths.
Evidence location	backend/src/common/filters/all-exceptions.filter.spec.ts; documents/testing/security-review.md
Gap / required action	Complete auth/data-access event coverage, centralized retention, alerting and incident-response evidence are not established.
Owner	HW development plus security/infra owners; final reviewer pending

A10 — Server-Side Request Forgery

Field	Assessment
Status	Partial
Implemented evidence	Image HTTPS host allowlist, no credentials/unsafe paths; provider/return destinations restricted; gateway origin is server configuration.
Evidence location	frontend/src/config/room-images.ts; frontend/tests/payment.test.mjs; frontend/tests/rooms.test.mjs
Gap / required action	No live network-egress/DNS-rebinding test. Frontend Next.js dependency advisory includes Image Optimization risks; patching and reassessment remain blockers.
Owner	HW development plus security/infra owners; final reviewer pending

3. Current dependency scan

Repository	Low	Moderate	High	Critical	Total
backend	0	1	3	0	4
frontend	0	0	0	1	1
gateway	1	1	0	0	2

Counts are npm affected-package counts, not counts of independently exploitable vulnerabilities. Advisory applicability needs code/path review. Dev and production dependencies are included; the raw scan is not a

production-only risk determination.

backend findings

- **@nestjs/platform-express — high.** Transitive affected-package dependency chain reported by npm. Fix available: yes, per npm.
- **body-parser — high.** body-parser vulnerable to Denial of Service via trailing bytes after a compressed request body Fix available: yes, per npm.
- **fast-uri — moderate.** fast-uri vulnerable to URI scheme spoofing via percent-encoded scheme decoding; fast-uri vulnerable to improper path equivalence in relative reference normalization; fast-uri vulnerable to host confusion via unchecked WHATWG host canonicalization; fast-uri vulnerable to scheme injection via an unescaped first-segment colon in suffix references Fix available: yes, per npm.
- **multer — high.** multer vulnerable to Denial of Service via a pending asynchronous fileFilter after request teardown Fix available: yes, per npm.

frontend findings

- **next — critical.** Next.js: Pending `use cache` fill can leak Draft Mode content into regular responses and persisted pages; Next.js has cache poisoning of SSG and ISR pages in self-hosted applications; Next.js has information disclosure in development server's Model Context Protocol endpoint; Next.js has information disclosure in App Router metadata image routes via dynamicParams bypass; Next.js has cache poisoning in SSG/ISR rendering that leads to cross-user content substitution and persistent denial of service; Next.js has Server-Side Request Forgery in Image Optimization; Next.js: Unauthenticated Remote Code Execution in Image Optimization API when SVG files are used; Next.js: Denial of Service in App Router using Server Actions; next.js cache leak across root param values in nested 'use cache' functions; Next.js: Unauthenticated Remote Code Execution in `use cache` functions returning typed arrays Fix available: next 16.4.3.

gateway findings

- **fast-uri — moderate.** fast-uri vulnerable to URI scheme spoofing via percent-encoded scheme decoding; fast-uri vulnerable to URI scheme spoofing via percent-encoded scheme decoding; fast-uri vulnerable to improper path equivalence in relative reference normalization; fast-uri vulnerable to improper path equivalence in relative reference normalization; fast-uri vulnerable to host confusion via unchecked WHATWG host canonicalization; fast-uri vulnerable to host confusion via unchecked WHATWG host canonicalization; fast-uri vulnerable to scheme injection via an unescaped first-segment colon in suffix references; fast-uri vulnerable to scheme injection via an unescaped first-segment colon in suffix references Fix available: yes, per npm.
- **fastify — low.** fastify is vulnerable to header validation bypass via case-sensitive propertyNames Fix available: fastify 5.12.7.

4. Verification commands and evidence status

Run `npm audit --json` in backend, frontend and gateway without applying fixes. Run backend unit coverage, frontend tests and gateway tests; restore the DB to rerun security HTTP checks. The current HTTP attempt was blocked by DB timeout. No clean scan, successful staging TLS test or fully compliant OWASP status is asserted.

5. Remediation/sign-off

Security owner should triage high/critical findings, apply compatible dependency upgrades in a separate reviewed change, rerun build/tests/browser checks and scans, complete account-lockout/session/audit requirements and collect TLS/egress evidence. Record reviewer/date only after reevaluation; this report does not fabricate approval.

Evidence and sign-off

Current requirement/screen mapping: release traceability.

Prepared from executable results and source inspection; reviewer/supervisor acceptance is not supplied.

Do not attach real environment files, passwords, JWTs, card data or raw provider responses.